Vulnerability Assessment Report

Single Finding Focus: Hardcoded Administrative Credentials & Policy Bypass

Target Application:	Milestone Management (Django)	**Severity Level:**	**CRITICAL (CVSS 9.8)**
Vulnerability Name:	Hardcoded Credentials & Backdoor Exception	**CWE ID:**	CWE-798, CWE-259, CWE-307
OWASP Classification:	A07:2021 — Identification & Authentication Failures	**Assessment Scope:**	Internal Application Security Audit
Audit Status:	**REJECTED / FAIL**	**Remediation Priority:**	**P0 (Immediate Hotfix Required)**

1. Executive Summary

During the cybersecurity and IT vulnerability audit of the project codebase, a **Critical Severity flaw** was discovered involving hardcoded administrative account credentials, automated default provisioning of an unauthenticated superuser, and explicit policy exclusions that bypass all NIST SP 800-63B and OWASP password validation and brute-force defenses. Because this vulnerability exposes full root/superuser control to unauthorized actors with zero technical barriers, the project **cannot pass the organization IT cybersecurity review** until full remediation is achieved.

2. Technical Description & Mechanism

The vulnerability consists of three interrelated components in the application code:

- **Automated Hardcoded User Creation:** In projects/models.py, the function get_default_master_user_id() automatically executes during model lifecycle operations, creating a superuser account with username **'aman'** and default password **'123456'** whenever a project is initialized without an explicit owner.
- **Explicit NIST Password Policy Bypass:** In projects/validators.py, an explicit exemption function is_master_admin(user, password) intercepts validation. All 7 enterprise NIST SP 800-63B password validators (minimum length, complexity, dictionary, breached password check via Have I Been Pwned) contain an early return statement exempting user 'aman', allowing the master administrator account to maintain a trivial 6-character breached password.
- **Brute-Force Lockout Exemption:** In gantt_app/settings.py, the rate-limiting and lockout middleware (django-axes) is explicitly configured with AXES_WHITELIST_USERS = ['aman']. This disables account lockout protection exclusively for the highest-privileged account, allowing unlimited automated credential stuffing attacks.

3. Source Code Evidence & Locations

Component / File	Identified Insecure Implementation

Model Default Provisioning
projects/models.py:43-59
	`def get_default_master_user_id():`
	`  user, created = User.objects.get_or_create(username='aman', ...)`
	`  if created:`
	`  **user.set_password('123456')**`
	`  user.save()`
	`  return user.id`

Policy Validation Bypass
projects/validators.py:32-41
	`def is_master_admin(user, password=None):`
	`  if user and str(user.username).lower() == 'aman':`
	`  **return True** # Exempted from all NIST/OWASP rules`
	`  return False`

Brute-Force Protection Whitelist
gantt_app/settings.py:134
	`# Brute-Force & Credential Stuffing Defense`
	`AXES_FAILURE_LIMIT = 5`
	`AXES_WHITELIST_USERS = ['aman']` # Lockout disabled for admin

4. Threat & Business Impact Analysis

- **Complete Administrative Takeover:** Any actor aware of the codebase or running basic credential enumeration can log in as aman with password 123456, acquiring full Django superuser privileges.
- **Total Data Confidentiality & Integrity Loss:** The master admin has unrestricted authority to read, alter, export, or purge all project schedules, financial budgets, corporate employee rosters, and database snapshots.
- **Compliance & Regulatory Failure:** Hardcoded passwords directly violate ISO 27001 (Control A.9.4.3), SOC 2 (Trust Services Criteria CC6.1), NIST SP 800-63B, and standard corporate IT policy guidelines.
- **Automated SAST Detection:** Static code scanners (SonarQube, Bandit, Semgrep, Trivy) flag hardcoded plaintext credentials as severe blocking defects, resulting in automated pipeline failure.

5. Step-by-Step Remediation Action Plan

- **Step 1 — Remove Hardcoded Superuser Generation:** In projects/models.py, delete get_default_master_user_id() and remove the default assignment on Project.owner.
- **Step 2 — Enforce Universal Password Policy:** In projects/validators.py, remove is_master_admin() and eliminate all exemption clauses so NIST/OWASP validation applies equally to all accounts.
- **Step 3 — Eliminate Lockout Whitelist:** In gantt_app/settings.py, set AXES_WHITELIST_USERS = [] so all users are protected against dictionary and credential stuffing attacks.
- **Step 4 — Standardize Administrative Provisioning:** Create administrative accounts only through Django's standard CLI utility (python manage.py createsuperuser) or secure environment variable bootstrapping.
- **Step 5 — Force Password Rotation:** Immediately rotate credentials for any existing accounts created under the hardcoded configuration.

AUDIT VERDICT: NON-COMPLIANT (FAIL)
The project fails organizational security criteria due to hardcoded administrative credentials. Deployment to production environments must be blocked until the remediation steps are completed and re-verified.